

Password & Multi-Factor Authentication Policy

Credential standards for staff and managed environments (PR.AA)

Document ID: BVT-POL-033

Version: 1.0

Issued: July 02, 2026

Effective Date: _____

Purpose, Scope, and Authority

This policy is part of the BVTech Written Information Security Program, aligned to the NIST Cybersecurity Framework (CSF) 2.0. It applies to all BVTech LLC personnel, contractors, systems, and, where adopted by a client, the client's covered environment. The Managing Partner (or designated security officer) owns this policy, reviews it at least annually, and approves exceptions in writing. Violations may result in disciplinary action up to termination of employment or contract.

Exception process: submit written request describing the business need, compensating controls, and duration. Exceptions expire after 12 months unless renewed. NIST CSF 2.0 references shown per section (GV, ID, PR, DE, RS, RC).

Password Standards

- Minimum 14 characters for user accounts; 20+ or passphrases for privileged and service accounts.
- No password reuse across systems; unique per site, enforced via the enterprise password manager.
- No forced periodic rotation absent compromise indicators (per NIST SP 800-63B); immediate rotation upon suspected exposure.
- Screening against known-breached password lists where the platform supports it.
- Prohibited: passwords in email, chat, spreadsheets, tickets, code, or documentation; sharing personal credentials.

Multi-Factor Authentication

- Required for: all email/identity platforms, VPN and remote access, password manager, RMM/PSA/security consoles, financial systems, and any internet-facing admin interface.
- Preferred factors: FIDO2 security keys or platform passkeys > authenticator app push with number matching > TOTP codes. SMS is a last resort and prohibited for privileged accounts.
- MFA fatigue protections enabled (number matching, throttling); users must report unexpected prompts immediately as a suspected compromise.

Password Manager

- All business credentials are stored in the approved enterprise password manager with role-based vaults and audit logging.
- Client credentials live in client-scoped vaults; access follows least privilege and is removed at offboarding.
- Emergency access (break-glass) procedures are documented in the Access Control Policy.